

SECURITY ASSESSMENT REPORT

Client: Legacy Corp Internal Lab (fictional)

Assessment Type: Network Penetration Test – MITM via ARP Spoofing

Date: May 28, 2026

Assessor: Chijioke Chukwuemeka Lewis

Classification: Confidential – For Recruitment Portfolio Only

1.0 Executive Summary

An internal penetration test was conducted against a simulated enterprise network to validate exposure to Layer 2 Man-in-the-Middle attacks. The assessment confirmed that a low-privilege attacker on the Guest WiFi segment could successfully intercept and modify all traffic between internal servers and the domain controller using ARP spoofing.

Business Impact: Critical

Credential Theft: Plaintext HTTP, SMB, and LDAP traffic observed, allowing full domain compromise.

Data Exfiltration: Attacker gains silent access to payroll, customer data, and internal APIs.

Regulatory Risk: Fails NDPA 2023 + PCI-DSS 11.4 requirements for network segmentation and encryption.

The attack requires only \$0 in tools and <60 seconds to execute. Immediate remediation is recommended. All testing was performed in an isolated lab with no impact to production systems.

| Finding | CVSS 3.1 | Risk | Status |

| ARP Spoofing – Lack of Dynamic ARP Inspection | 8.8 High | Critical | Open

| Flat Network – Guest WiFi routes to CorpLAN | 7.5 High | High | Open |

| Unencrypted Internal Traffic HTTP/SMBv1 | 7.1 High | High | Open |

2.0 Technical Findings

2.1 Finding: ARP Spoofing Allows Full Traffic Interception

CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N – 8.8 High

Description: The CorpLAN and Guest WiFi share a single broadcast domain without Dynamic ARP Inspection. An attacker using from Kali Linux was able to poison the ARP cache of victim host and gateway .

Evidence:

Wireshark capture shows duplicate ARP replies for from MAC gateway and attacker within 1s intervals. on victim confirmed gateway MAC changed to attacker MAC. Full HTTP sessions to were captured in plaintext via .

Attack Path:

Guest WiFi → Send forged ARP replies → Victim + Gateway route through attacker → Intercept/modify traffic → Forward to maintain connectivity.

2.2 Finding: Lack of Network Segmentation

CVSS:3.1/AV:A/AC:L/PR:L/UI:N/S:C/C:L/I:L/A:N – 7.5 High

Untrusted Guest network has L3 routing to CorpLAN servers. No ACLs or VLANs prevent a compromised guest device from reaching Domain Controller on ports 389/LDAP and 445/SMB.

3.0 Remediation Roadmap

| Priority | Recommendation | Effort | Timeline | Standard |

| **P0 – 7 Days** | Enable Dynamic ARP Inspection on all access switches. Bind IP-MAC on gateway | Low | 1 week | NIST 800-53 SC-7 |

| **P1 – 30 Days** | Implement VLANs: Separate Guest, Corp, Server. Deny Guest→CorpLAN at firewall | Medium | 30 days | CIS Control 12 |

| **P1 – 30 Days** | Force HTTPS + SMB signing. Disable SMBv1, LDAP signing required | Medium | 30 days | PCI-DSS 4.1 |

| ****P2 – 90 Days**** | Deploy Zero Trust Network Access. Remove implicit trust in CorpLAN | High | Q3 2026 | NIST 800-207 |

Validation: Re-test with post-remediation. DAI should drop forged packets and log alerts.

4.0 Methodology & Tools

Testing followed PTES and OWASP WSTG frameworks. Scope: . Tools: Kali Linux, arpspoof v2.4, Wireshark 2.6, Ubuntu 14.04 victim. No denial-of-service or data destruction performed.

Conclusion: Legacy Corp's current network design allows trivial Layer 2 attacks with enterprise-wide impact. Implementing DAI + VLANs eliminates this entire attack class. The organization should adopt a "Zero Trust" posture where no device is trusted based on network location alone.

Appendix A: Full Wireshark PCAP + screenshots available upon request.

Prepared by: chijioke chukwuemeka Lewis | GitHub: <https://github.com/lewis1024-debug> | lewis4chi@yahoo.com